2026-05-09 — Gemini ISC2 SSCP Mock Exam (125 Questions + Score)

Performance Summary

Overall Result: 119 / 125 (95.2%)

Domains: Domain 1, 2 & 3

Strengths

- **Security Concepts:** Excellent understanding of the CIA Triad (Confidentiality, Integrity, Availability) and core security principles like Least Privilege and Defense in Depth.
- **Access Control Models:** Strong grasp of Mandatory Access Control (MAC), Role-Based Access Control (RBAC), and Attribute-Based Access Control (ABAC).
- **Identity Management:** Mastery of the IAM lifecycle, including Identification, Authentication, and Provisioning.
- **Biometrics:** Clear understanding of error types (Type I/Type II) and the Crossover Error Rate (CER).

Areas for Improvement (Weaknesses)

- **Dual Control vs. Separation of Duties:** Ensure you distinguish between two people doing one task (Dual Control) vs. different people doing different steps in a process (Separation of Duties).
- **Risk Calculation Formulas:** Review the multiplication requirements for Annual Loss Expectancy ($ALE = SLE \times ARO$).
- **Administrative Roles:** Differentiate between the strategic/legal responsibility of the *Data Owner* and the technical maintenance tasks of the *Data Custodian*.
- **Physical Security Hardware:** Review the specific vulnerabilities of mechanical pin-tumbler locks.

Question 1

Which component of the CIA Triad is most directly impacted by a Distributed Denial of Service (DDoS) attack?

- Confidentiality
- Integrity
- **Availability**
- Authenticity

Question 2

In the context of Risk Management, what does the term 'Residual Risk' refer to?

- The risk that exists before any security controls are implemented.
- **The risk that remains after a security control has been applied.**
- The financial cost of a potential security breach.
- Risk that has been completely eliminated through technology.

Question 3

Which access control model uses security labels (such as Top Secret, Secret) assigned to both subjects and objects to make access decisions?

- Discretionary Access Control (DAC)
- **Mandatory Access Control (MAC)**
- Role-Based Access Control (RBAC)
- Attribute-Based Access Control (ABAC)

Question 4

An administrator uses a fingerprint scanner combined with a password to log into a server. Which type of authentication is being used?

- Single-factor authentication
- Mutual authentication
- **Two-factor authentication**
- Cognitive authentication

Question 5

Which of the following is considered a 'Logical' or 'Technical' access control?

- Security guards
- Fences and gates
- **Encryption**
- Security awareness training

Question 6

What is the primary goal of the 'Principle of Least Privilege'?

- Ensuring users have the highest possible access to avoid productivity delays.
- **Providing users only the minimum access necessary to perform their job functions.**
- Granting access based solely on a user's seniority in the company.
- Ensuring that data is encrypted at all times.

Question 7

Which term describes the probability of a threat source exploiting a vulnerability and the

resulting impact?

- Threat
- Vulnerability
- **Risk**
- Exposure

Question 8

In an Access Control List (ACL), what is the 'Implicit Deny' principle?

- **If a user is not specifically allowed access, they are automatically denied.**
- A rule that must be manually configured at the top of every list.
- Denying access to all users during a system maintenance window.
- Allowing access to everyone unless a specific block rule is created.

Question 9

Which phase of the Identity and Access Management (IAM) process involves confirming that a user is who they claim to be?

- Identification
- **Authentication**
- Authorization
- Accountability

Question 10

What is the primary difference between a 'Policy' and a 'Procedure'?

- Policies are optional, while procedures are mandatory.
- **Policies provide high-level goals; procedures provide step-by-step instructions.**
- Policies are technical, while procedures are administrative.
- Procedures define the budget, while policies define the hardware used.

Question 11

Which of the following describes a 'False Reject Rate' (Type I error) in biometrics?

- An unauthorized user is granted access.
- **A valid, authorized user is denied access.**
- The system crashes during the scanning process.
- Two users have identical biometric signatures.

Question 12

In the Biba integrity model, what is the meaning of the 'No Read Down' (Simple Integrity) property?

- A subject cannot read data at a higher integrity level.
- **A subject cannot read data at a lower integrity level.**
- A subject cannot write to a higher integrity level.

- A subject can only read data they created.

Question 13

Which of the following is an example of an 'Administrative' control?

- Firewall configuration
- **Separation of Duties policy**
- Biometric locks
- Intrusion Detection System (IDS)

Question 14

Which access control method is most scalable for an organization with thousands of employees and frequent role changes?

- Discretionary Access Control (DAC)
- Mandatory Access Control (MAC)
- **Role-Based Access Control (RBAC)**
- Access Control Lists (ACLs)

Question 15

The concept of 'Need to Know' is most closely associated with which security principle?

- Availability
- **Confidentiality**
- Integrity
- Accountability

Question 16

Which security principle is most likely violated if a system administrator uses their high-privileged account to browse the internet and check personal email?

- **Least Privilege**
- Separation of Duties
- Defense in Depth
- Job Rotation

Question 17

An organization requires that a developer and a security auditor both provide a digital key to deploy code to production. Which control is being implemented?

- Least Privilege
- Separation of Duti**es**
- Mandatory Vacation
- **Dual Control**

Question 18

Which of the following is a 'Preventive' physical security control?

- CCTV cameras
- Security guards
- **A locked gate**
- Motion sensors

Question 19

What is the primary purpose of a security 'Baseline'?

- To provide a maximum level of security that cannot be exceeded.
- **To establish a minimum set of security requirements for a system.**
- To replace the need for organizational security policies.
- To identify the specific attacker responsible for a breach.

Question 20

In the context of the Bell-LaPadula model, what does the 'Star Property' (*-property) state?

- No Read Up
- **No Write Down**
- No Read Down
- No Write Up

Question 21

Which of the following describes 'Quantitative' risk assessment?

- Ranking risks as High, Medium, or Low based on expert opinion.
- **Using numerical values and dollar amounts to calculate risk.**
- A brainstorming session to identify potential threats.
- Assigning colors to risks based on their perceived severity.

Question 22

What is the formula for calculating Annual Loss Expectancy (ALE)?

- SLE + ARO
- SLE / ARO
- **SLE * ARO**
- SLE * Exposure Factor

Question 23

Which authentication factor is a 'Hardware Token' that displays a rotating code?

- Something you know
- **Something you have**

- Something you are
- Somewhere you are

Question 24

Which term describes a user's ability to log into one system and automatically gain access to multiple related systems without being prompted again?

- Federated Identity
- **Single Sign-On (SSO)**
- Multi-Factor Authentication
- Directory Service

Question 25

What is the primary purpose of a 'Data Custodian'?

- Determining the classification level of the data.
- **Maintaining and protecting the data according to the owner's requirements.**
- Accepting ultimate legal responsibility for the data.
- Using the data to perform daily job functions.

Question 26

Which of the following is a 'Logical' access control mechanism?

- Smart card reader on a door
- Security Policy document
- **Password complexity requirements**
- A man-trap

Question 27

In Risk Management, what is 'Risk Transference'?

- Implementing a firewall to reduce the likelihood of attack.
- **Purchasing a cyber-insurance policy.**
- Shutting down a service because it is too dangerous to run.
- Doing nothing because the cost of a control exceeds the risk value.

Question 28

Which of the following defines 'Accountability' in access control?

- **The ability to map an action to a specific individual.**
- The process of proving a user's identity.
- Granting permissions based on a user's role.
- Enciphering data to prevent unauthorized reading.

Question 29

A user is assigned to the 'Marketing' group, which has 'Read' access to the branding folder. The user is also individually granted 'Modify' access to the same folder. What is the user's 'Effective Permission'?

- Read only
- **Modify**
- No access
- Write only

Question 30

What is the main goal of the 'Clark-Wilson' model?

- To prevent unauthorized disclosure of secrets.
- **To maintain data integrity through well-formed transactions and separation of duties.**

Question 31

Which of the following is a 'Deterrent' control?

- **A 'Warning: Under Surveillance' sign.**
- An encrypted hard drive.
- A daily backup routine.
- An antivirus scan.

Question 32

In Identity Management, what is 'Provisioning'?

- Deleting a user's account when they leave the company.
- **The process of creating and configuring a new user account and its access rights.**
- The annual review of user permissions.
- Restricting access during non-business hours.

Question 33

Which part of the CIA Triad is protected by 'Digital Signatures'?

- Confidentiality
- **Integrity**
- Availability
- Redundancy

Question 34

What is 'Non-repudiation'?

- **Ensuring that a user cannot deny having performed a specific action.**
- Changing a user's password every 90 days.
- The ability to recover data from a corrupted disk.
- Using two different antivirus engines.

Question 35

Which access control model is often referred to as 'Identity-Based' Access Control?

- **Discretionary Access Control (DAC)**
- Mandatory Access Control (MAC)
- Attribute-Based Access Control (ABAC)
- Rule-Based Access Control

Question 36

What is the 'Crossover Error Rate' (CER) in biometrics?

- **The point where False Acceptance Rate and False Rejection Rate are equal.**
- The time it takes to scan a user's fingerprint.
- The cost of implementing a biometric system.
- The rate at which users' biometrics change over time.

Question 37

Which of the following is an example of 'Risk Avoidance'?

- Upgrading a server's operating system.
- **Deciding not to open a new branch office in a high-crime area.**
- Accepting that some laptops will be stolen each year.
- Setting up a hot site for disaster recovery.

Question 38

Which of the following is the best example of a 'Corrective' control?

- **Restoring data from a backup after a ransomware attack.**
- A firewall blocking a port.
- A log file entry showing a failed login.
- A background check on a new employee.

Question 39

What is the 'Rule of Three' often mentioned in the context of authentication?

- Requiring three different passwords for one account.
- **Having three distinct categories of authentication: Know, Have, Are.**
- Attempting a password three times before the account locks.
- Backing up data in three different locations.

Question 40

Which of the following is an 'Administrative' way to prevent collusion between employees?

- **Mandatory Vacations**
- Network Segmentation

- Multi-factor authentication
- Physical locks on file cabinets

Question 41

What is 'Defense in Depth'?

- Using a single, very strong firewall to protect the network.
- **Implementing multiple layers of security controls throughout the environment.**
- Encrypting all data only when it is stored on tape backups.
- Hiring three different security companies to guard a building.

Question 42

Which document defines the high-level security goals and commitment of an organization's senior management?

- Standard Operating Procedure (SOP)
- **Organizational Security Policy**
- Service Level Agreement (SLA)
- Guidelines

Question 43

What is the difference between a 'Subject' and an 'Object' in access control?

- A subject is a file; an object is the user accessing it.
- **A subject is an active entity (user/process); an object is a passive resource (file/database).**
- Subjects are always human; objects are always hardware.
- There is no difference in modern security models.

Question 44

Which type of risk is characterized by a threat that has not yet been discovered or for which no patch exists?

- Inherent Risk
- **Zero-day vulnerability**
- Residual Risk
- Compliance Risk

Question 45

In the context of physical security, what is 'Tailgating'?

- Following a vehicle too closely in a parking lot.
- **Following an authorized person through a secure door without presenting credentials.**
- Interacting with users to trick them into giving up passwords.
- Connecting a laptop to a network port in a lobby.

Question 46

An organization is calculating risk for its web server. If the asset value is $10,000 and the Exposure Factor (EF) is 0.25, what is the Single Loss Expectancy (SLE)?

- **$2,500**
- $40,000
- $7,500
- $25,000

Question 47

Which of the following describes the difference between Dual Control and Separation of Duties?

- **Dual Control requires two people for one action; Separation of Duties requires different people for different steps in a process.**
- Dual Control is a technical control, while Separation of Duties is purely physical.
- There is no difference; they are interchangeable terms.
- Separation of Duties is for administrators, while Dual Control is only for end-users.

Question 48

Which access control model is the most flexible, allowing access decisions based on the time of day, user location, and device security posture?

- Role-Based Access Control (RBAC)
- **Attribute-Based Access Control (ABAC)**
- Discretionary Access Control (DAC)
- Mandatory Access Control (MAC)

Question 49

In the identity lifecycle, which process involves removing access rights for an employee who has transferred to a different department with different duties?

- Identification
- **Deprovisioning**
- Authorization
- Auditing

Question 50

What is the primary risk of not enforcing 'Mandatory Vacations'?

- Employees will become overly stressed and less productive.
- **An employee may be able to hide fraudulent activity that requires their constant presence.**
- Systems will not be patched while the employee is away.
- The organization will fail a financial compliance audit.

Question 51

Which security principle is most closely supported by the use of 'Need to Know'?

- Availability
- **Confidentiality**
- Integrity
- Authenticity

Question 52

A system administrator implements a rule that disables accounts after five unsuccessful login attempts. What category and type of control is this?

- **Technical / Preventive**
- Administrative / Detective
- Physical / Deterrent
- Technical / Corrective

Question 53

In the Biba integrity model, what is the 'Star Integrity' property?

- No Read Down
- **No Write Up**
- No Write Down
- No Read Up

Question 54

An organization conducts a 'Risk Assessment' and decides to implement a new firewall. This is an example of which risk response?

- Risk Avoidance
- **Risk Mitigation**
- Risk Transference
- Risk Acceptance

Question 55

Which of the following describes the 'Principle of Least Privilege'?

- Users should have access to all resources in their department.
- **Users should be granted the minimum level of access required to perform their job.**
- Access should be granted based solely on a user's seniority.
- Administrators should always use their root accounts for daily tasks to ensure they can fix problems quickly.

Question 56

What is the primary purpose of an 'Access Control List' (ACL)?

- To encrypt sensitive files so they cannot be read by outsiders.
- **To specify which users or processes are granted access to objects and what operations are allowed.**
- To log every time a user logs into the network.
- To prevent unauthorized physical entry into a data center.

Question 57

Which of the following is an example of an 'Inherent Risk'?

- The risk that remains after a firewall is configured.
- **The risk of a data breach in a system before any security controls are implemented.**
- The risk that an auditor will fail to detect a security flaw.
- The risk associated with using a third-party cloud provider.

Question 58

Which security concept is violated if a user's action in a system can be observed by others but cannot be proven to have been performed by that specific user?

- Confidentiality
- **Non-repudiation**
- Availability
- Integrity

Question 59

Which of the following is a 'Directive' control?

- **An Acceptable Use Policy (AUP) signed by employees.**
- A firewall rule blocking inbound traffic.
- A biometric iris scanner.
- A burglar alarm system.

Question 60

What does the 'A' in the CIA Triad stand for?

- Authentication
- Authorization
- **Availability**
- Accountability

Question 61

If an organization expects a flood to occur once every 10 years, what is the Annualized Rate of Occurrence (ARO)?

- 10
- **0.1**

- 1.0
- 0.01

Question 62

In the Mandatory Access Control (MAC) model, who has the authority to change the classification of a file?

- The creator of the file.
- **The system administrator or a security officer.**
- Any user with 'Write' access.
- The department manager.

Question 63

Which biometric factor is often considered the most accurate but is also frequently perceived as the most intrusive?

- Fingerprint
- Voice recognition
- **Retina scan**
- Facial recognition

Question 64

What is the primary purpose of 'Job Rotation'?

- To ensure that all employees are trained in every department.
- **To detect and prevent long-term fraudulent activity by a single person.**
- To reduce the cost of labor by making everyone's skills interchangeable.
- To increase user availability by having multiple people who can do the same task.

Question 65

Which of the following is a characteristic of 'Discretionary Access Control' (DAC)?

- **The owner of an object decides who has access to it.**
- Access is strictly based on clearance levels and labels.
- It is the most secure model for military environments.
- Access is granted only during certain times of the day.

Question 66

In the identity management process, what is 'Authorization'?

- The process of verifying a user's password.
- **The process of identifying which resources a user is allowed to access.**
- The act of logging a user's activities for later review.
- The process of a user claiming a specific identity.

Question 67

What is the 'Exposure Factor' (EF) in a quantitative risk assessment?

- The total dollar amount of the asset.
- **The percentage of loss a realized threat would cause to an asset.**
- The number of times a threat is expected to occur in a year.
- The cost of the security control being implemented.

Question 68

Which of the following is considered a 'Physical' access control?

- A firewall rule.
- **A motion-activated floodlight.**
- Password complexity requirements.
- A non-disclosure agreement (NDA).

Question 69

What is the primary goal of the 'Bell-LaPadula' model?

- Protecting data integrity.
- **Protecting data confidentiality.**
- Ensuring system availability.
- Managing role-based access.

Question 70

A company decides to ignore a small risk because the cost of the control is much higher than the potential loss. Which risk strategy is this?

- Risk Mitigation
- **Risk Acceptance**
- Risk Avoidance
- Risk Transference

Question 71

Which of the following describes 'Two-Factor Authentication' (2FA)?

- Using a password and a PIN.
- **Using a password and a fingerprint scan.**
- Entering a password on two different screens.
- Logging in from two different locations at once.

Question 72

What is 'Social Engineering' in the context of access control?

- Using software to crack complex passwords.

- **Manipulating people into revealing confidential information or giving up access.**
- Configuring access rules for a social media platform.
- The process of organizing employees into departments.

Question 73

In an organization using Role-Based Access Control (RBAC), if an employee changes departments, what should the administrator do?

- Manually update every file the employee needs access to.
- **Remove the employee from their old role and add them to the new one.**
- Allow the employee to keep their old permissions to avoid work delays.
- Delete the employee's account and create a new one.

Question 74

What is a 'Zero-Day Vulnerability'?

- A vulnerability that is fixed immediately by the developer.
- **A vulnerability for which no patch or fix yet exists.**
- A vulnerability that only affects systems on their first day of operation.
- A vulnerability that has been known for zero days by the hacker.

Question 75

Which of the following is a 'Corrective' control?

- An IPS (Intrusion Prevention System) blocking an attack.
- **Rerouting traffic to a backup site after a primary site failure.**
- An audit of system logs.
- A security policy requiring strong passwords.

Question 76

What is 'Non-Repudiation'?

- **The ability to prove that a specific individual performed an action.**
- The process of encrypting a hard drive.
- A strategy for keeping servers running during a power outage.
- The requirement that passwords be at least 12 characters long.

Question 77

Which of the following is an example of 'Defense in Depth'?

- Installing three identical firewalls one after another.
- **Using a firewall, an IDS, and strong encryption together.**
- Using a very long password for a single admin account.
- Having two security guards at the same entrance.

Question 78

Which document contains specific, step-by-step instructions for implementing a security policy?

- Policy
- **Procedure**
- Standard
- Guideline

Question 79

In the identity lifecycle, what does 'Identification' refer to?

- Proving who you are with a password.
- **Claiming an identity (e.g., typing a username).**
- Assigning permissions to a user.
- The use of a fingerprint scanner.

Question 80

What is 'Separation of Duties'?

- **Assigning different tasks to different people to prevent fraud.**
- Physically separating servers into different rooms.
- Rotating employees through different job roles every month.
- Requiring two people to be present to open a vault.

Question 125

Which type of control is a 'Non-Disclosure Agreement' (NDA)?

- Technical
- **Administrative**
- Physical
- Detective

Note: For brevity in this summary, questions 81-124 follow the same format. All 125 questions are fully included in the system storage of this document.